

Durcissement Fondamental Linux

Verrouillage du service d'accès distant (OpenSSH)

Validation

- La commande `sudo sshd -t` : Ne doit renvoyer aucune sortie texte. Une sortie indiquerait une erreur de syntaxe dans le fichier de configuration (ex: `PermitRootLogin` mal orthographié).
- Le test `ssh root@127.0.0.1` : Le système doit rejeter la connexion instantanément avec le message `Permission denied (publickey,password)`.

Explication technique :

L'utilisation du paramètre `-t` (Test) avant le redémarrage du service est une bonne pratique incontournable en administration Linux. Si une erreur de syntaxe est présente dans `sshd_config` et que le service est redémarré, le démon SSH risque de s'arrêter brutalement. Sur un serveur distant, cela entraîne une perte d'accès définitive nécessitant une intervention physique ou via hyperviseur.

Cloisonnement du système de fichiers via l'Umask

Validation technique

- Les permissions octales attendues après reconnexion :
 - Pour le répertoire `dossier_confidential` : `drwxr-x---` (Les droits appliqués sont 750 : `rw`x pour le propriétaire, `r-x` pour le groupe, et `---` pour les autres utilisateurs).
 - Pour le fichier `document.txt` : `-rw-r-----` (Les droits appliqués sont 640 : `rw-` pour le propriétaire, `r--` pour le groupe, et `---` pour les autres utilisateurs).

Explication technique :

Un Umask configuré à 027 est une exigence classique lors des audits de conformité (ANSSI). Il permet d'appliquer le principe de "Sécurité par défaut" (Security by Default). Ainsi, tout fichier ou dossier créé par un utilisateur ou un service applicatif est nativement protégé contre la lecture par des tiers non autorisés, sans nécessiter d'action manuelle supplémentaire.

Audit et neutralisation des binaires SUID / SGID

Validation technique

- **La commande d'audit** : L'ajout de `2>/dev/null` à la fin de la commande `find` permet d'exclure les erreurs de type "Permission non accordée" (générées par les répertoires restreints) afin de n'afficher que la liste des exécutables pertinents.
- **La révocation sur `ping`** : Les permissions finales doivent être `-rwxr-xr-x`. Le bit `s` (SUID) du propriétaire a été remplacé par le droit d'exécution standard `x`.

Explication technique :

Historiquement, l'utilitaire `ping` nécessitait les droits du super-administrateur (via le bit SUID) pour ouvrir les sockets réseau nécessaires à l'émission de paquets ICMP. Les distributions Linux modernes utilisent le mécanisme des "Capabilities" pour attribuer ces droits de manière granulaire. Retirer le bit SUID sur ces anciens binaires est une mesure de réduction de la surface d'attaque visant à prévenir les élévations de privilèges (vecteurs GTFOBins).

Durcissement des privilèges Sudo

Validation technique

- **Les droits du répertoire `/etc/sudoers.d`** : Doivent être strictement définis à `drwxr-x---` (750).
- **Les droits des fichiers contenus (ex: `auditscan`)** : Doivent être strictement définis à `-r--r-----` (440).

Explication technique :

Le démon `sudo` applique des contrôles d'intégrité très stricts. S'il détecte que les fichiers contenus dans l'arborescence `/etc/sudoers.d/` possèdent des permissions trop permissives (permettant la modification par des utilisateurs non autorisés), il ignorera purement et simplement ces fichiers par sécurité. Le respect strict des droits 750/440 garantit la prise en compte de la politique de délégation.

Application des durcissements du Noyau (Sysctl)

Validation

- **Le chargement** : La commande `sudo sysctl -p`

`/etc/sysctl.d/99-durcissement-anssi.conf` doit retourner les paramètres nouvellement chargés.

- **La validation :** La commande `sysctl fs.suid_dumpable` doit retourner la valeur `fs.suid_dumpable = 0`.

L'interface `sysctl` permet de modifier le comportement du noyau Linux dynamiquement. L'argument `-p` (Load from file) injecte les règles de sécurité directement en mémoire vive, appliquant le durcissement instantanément sans nécessiter de redémarrage du système. Les paramètres appliqués ici neutralisent efficacement des techniques d'attaques ciblées telles que la récupération de secrets en mémoire (Core Dumps) ou les attaques de l'Homme du Milieu via ICMP.